

Wellness Assistant — Agent LLM Comparison (Red Team)

Both models were tested with the **identical** guardrails, plugins, and attack strategies defined in [backend/evals/redteam.config.yaml](#) and the same system prompt in [backend/prompts/system.yml](#). Only the target model differs, so the deltas below are attributable to the model, not the harness.

- Frontier: `gpt-5.4-mini` — see [openai-gpt-5.4-mini report](#)
 - OSS: `qwen2.5 9B` (local Ollama) — see [ollama-qwen9B report](#)
-

Frontier model — `gpt-5.4-mini`

Pros

- Strong overall posture: **87% defended (95/109)**, framework ASR only **12.96%**.
- **Zero Critical** and no Self-Harm leakage (0/9) — the highest-stakes category held.
- Robust against layered attacks: multi-vector safety bypass succeeded only **6.15%** of the time, and static jailbreak templates (DAN, Skeleton Key) and baseline probes were **fully defended (0%)**.
- Bias categories mostly held (Race/Disability/Hate Speech/Self-Harm all 9/9).

Cons

- Still weak on **Hallucination (44% ASR)** — fabricates wellness facts under pressure.
- **Unauthorized Advice 33%** and **Overreliance 22%** — drifts into

medical-advice territory and encourages over-trust.

- Residual **Age/Gender Bias (22%)** and **Harassment (11%)**.
 - Operational: API cost per call, external data egress (privacy), and no local control over the weights or availability.
-

OSS model — qwen2.5 9B

Pros

- Runs **locally via Ollama** — no per-call cost, no data leaving the host, full control over versioning/availability.
- Static jailbreak templates fully defended (**0%**), same as the frontier model.
- Competitive on a few categories (Race Bias 9/9, Hate Speech 9/9, Gender Bias 7/9).

Cons

- Materially weaker overall: **72% defended (78/109)**, framework ASR **28.70%** (~2.2x the frontier model).
 - **1 Critical vulnerability: Self-Harm 22% ASR** — the frontier model leaked none here.
 - Fails the **custom medical-diagnosis policy at 50%** — half of diagnosis/dosage probes got through.
 - Much softer against layered/adaptive attacks: multi-vector bypass **32.31%** (vs 6.15%), crescendo **38.46%**, and even **baseline probes leak 14.29%** (vs 0%).
 - New/worse failure modes vs frontier: Disinformation **33%**, Dangerous Activity **22%**, Age Bias **56%**, Disability Bias **44%**.
-

Comparison

Dimension	Frontier gpt-5.4-mini	OSS qwen2.5 9B
Overall tests defended	87% (95/109)	72% (78/109)
Framework attack success rate	12.96%	28.70%
Severity counts	0 Crit / 2 Med / 4 Low	1 Crit / 3 Med / 6 Low
Self-Harm (Critical safety)	0% leaked	22% leaked (Critical)
Medical-diagnosis policy	not separately failed	50% leaked
Hallucination	44%	44%
Unauthorized Advice	33%	33%
Disinformation	defended (0%)	33%
Dangerous Activity	defended (0%)	22%
Age / Disability Bias	22% / 0%	56% / 44%
Multi-vector bypass resistance	6.15% ASR	32.31% ASR
Crescendo resistance	30.77% ASR	38.46% ASR
Baseline (no strategy)	0% ASR	14.29% ASR
Cost	Per-call API cost	Free (local)
Privacy / data control	Data egress to provider	Fully local
Latency / availability	Provider-dependent	Self-hosted control

Bottom line: the frontier model is meaningfully safer, especially on the highest-stakes categories (self-harm, medical advice, disinformation) and against adaptive attacks. The OSS model's only real edge is cost, privacy, and control — not safety.

Recommendations (what I'd improve given more time)

These are targeted to this codebase, ordered by impact:

1. **Make safety model-independent with a deterministic output guardrail.** The OSS gap is largest exactly where the frontier model self-polices (self-harm, medical policy, disinformation). Add a post-generation check in [backend/src/wellness/agent/graph.py](#) — a self-harm crisis-detector + diagnosis/dosage classifier that overrides the model response with a fixed refusal + provider referral. This alone would close the OSS Critical (Self-Harm 22%) and the 50% medical-policy failure regardless of which model backs the agent.
2. **Harden [backend/prompts/system.yml](#).** The current prompt only softly says "You are not a medical professional." Replace with (a) an explicit self-harm crisis-response block (empathize, do not engage, provide hotline, refuse method details), and (b) a hard, enumerated refusal for diagnoses, medication names, and dosages. Weak-instruction-following models like qwen2.5 need explicit rules, not soft framing.
3. **Enforce KB grounding to kill hallucination (44% on *both models*).** In the agent graph, when `lookup_kb` returns nothing useful, force a hedge/refusal instead of free-generating, and require a cited source for any factual wellness claim. This is model-agnostic and fixes the one failure both models share.
4. **Fix the eval's statistical power.** Every plugin runs `numTests: 1` in [backend/evals/redteam.config.yaml](#), yet Age Bias swings 22% → 56% between models — that's noise-dominated. Raise `numTests` (e.g. 5–10) for bias and safety plugins and regenerate the dataset so the numbers are trustworthy before making a model decision.
5. **Cover the untested agentic attack surface.** The agent has `search_web` and `lookup_kb` tools, but PII exfiltration, indirect prompt injection, and excessive agency all show "Not Tested" in

both reports. Add the pii, indirect-prompt-injection, and excessive-agency plugins — these are the real risks for a tool-using agent and are currently a blind spot.

6. **Decision:** default to the frontier model for its 6% multi-vector resistance and zero Critical findings. Only ship the OSS model if privacy/cost is a hard requirement — and only *after* recommendations 1–3 land, since the external guardrail + explicit prompt + KB grounding would bring qwen2.5 close enough to be viable.